

Threat Analysis Report

รายงานวิเคราะห์ภัยคุกคาม: กลุ่มต้องสงสัยชาวจีน
ใช้ประโยชน์จาก AI Agents

(Claude Code และ DeepSeek)

ในการโจมตีระบบรัฐบาลในหลายประเทศ

Suspected China-Linked Operators Leverage AI Agents
(Claude Code and DeepSeek) to Breach Government Systems
Across Multiple Countries

18/07/2026

TLP:CLEAR





สารบัญ

สารบัญ.....	1
บทสรุปสำหรับผู้บริหาร.....	2
Threat Actor Profiles	3
การวิเคราะห์เชิงเทคนิค.....	6
Tactics, Techniques, and Procedures (MITRE ATT&CK)	15
Indicators of Compromise (IoCs).....	17
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ.....	19
อ้างอิง (References).....	22



บทสรุปสำหรับผู้บริหาร

รายงานฉบับนี้เป็นการวิเคราะห์เชิงลึกของข้อมูลข่าวกรองที่ได้รับจากเซิร์ฟเวอร์ควบคุมและสั่งการ (C2) ที่ถูกเปิดเผยโดยไม่ได้ตั้งใจ พบว่ามีกลุ่มผู้ไม่หวังดีที่ต้องสงสัยว่ามีความเชื่อมโยงกับประเทศจีน ได้ดำเนินการโจมตีทางไซเบอร์ขนาดใหญ่ต่อระบบสำคัญของหน่วยงานภาครัฐและภาคการเงินในอย่างน้อย 4 ประเทศ ได้แก่ ไทย ออสเตรเลีย ไต้หวัน และไนจีเรีย รวมถึงการสอดแนมเบื้องต้นต่อเป้าหมายในสหรัฐอเมริกา สิ่งที่ทำให้แคมเปญนี้มีความโดดเด่นและน่าวิตกเป็นอย่างยิ่งคือ การนำโมเดลปัญญาประดิษฐ์ (AI) ระดับแนวหน้าสองระบบมาผนวกเข้ากับวงจรการโจมตีอย่างสมบูรณ์ โดย Claude Code ทำหน้าที่เป็นเครื่องย่นต์สั่งการและรันโค้ดมัลแวร์ ในขณะที่ DeepSeek-v4-pro ทำหน้าที่วิเคราะห์เหตุผล สร้างสคริปต์โจมตีเฉพาะเป้าหมาย และปรับแต่งเทคนิคหลบเลี่ยงการตรวจจับในแบบเรียลไทม์

กลุ่มผู้ไม่หวังดีได้สร้างโครงสร้างพื้นฐาน C2 ที่ประกอบด้วยเซิร์ฟเวอร์จำนวน 13 เครื่อง ซึ่งตั้งอยู่ในฮ่องกงและกระจายตัวข้ามผู้ให้บริการเครือข่ายอิสระ (ASN) ถึง 4 ราย โดยใช้มัลแวร์ประเภท C2 สองรูปแบบร่วมกัน ได้แก่ TencShell ซึ่งเป็น Go-based implant ที่มีต้นกำเนิดจาก Rshell framework และ Gshell ซึ่งเป็น C2 framework รอง ที่ทำงานคู่ขนานกันเพื่อเพิ่มความทนทานในการปฏิบัติการ โดยระบบทั้งสองกลุ่มนี้แชร์ทั้ง SSH Host Key Fingerprint และ TLS Certificate ร่วมกัน ซึ่งบ่งชี้ถึงการบริหารจัดการโครงสร้างพื้นฐานอย่างเป็นระบบ และต่อเนื่องจนถึงอย่างน้อยกลางเดือนมิถุนายน พ.ศ. 2569

สำหรับประเทศไทยโดยเฉพาะ พบว่าระบบบริหารจัดการบุคลากรออนไลน์ของหนึ่งในหน่วยงานรัฐบาลไทย (AMSS) ถูกเจาะระบบสำเร็จผ่านช่องโหว่ SQL Injection จนผู้ไม่หวังดีสามารถเข้าถึงแผงผู้ดูแลระบบ ติดตั้ง Web Shell ชนิด GIF Polyglot เพื่อรักษาการเข้าถึงอย่างต่อเนื่อง และขโมยข้อมูลส่วนบุคคลของเจ้าหน้าที่รัฐ อาทิ ชื่อ เลขบัตรประชาชน และตำแหน่งงาน ออกไปได้ ซึ่งถือเป็นการละเมิดที่ส่งผลกระทบโดยตรงต่อความมั่นคงของข้อมูลส่วนบุคคลภายใต้ พ.ร.บ.คุ้มครองข้อมูลส่วนบุคคล พ.ศ. 2562 และ พ.ร.บ. การรักษาความมั่นคงปลอดภัยไซเบอร์ พ.ศ. 2562

เหตุการณ์นี้สะท้อนถึงความจำเป็นเร่งด่วนในการยกระดับมาตรการรักษาความมั่นคงปลอดภัยของระบบสารสนเทศภาครัฐ โดยเฉพาะอย่างยิ่งในยุคที่ AI ถูกนำมาใช้เป็นอาวุธไซเบอร์อย่างเป็นรูปธรรม และดำเนินการเชิงรุกอย่างเร่งด่วนในการตรวจสอบระบบที่อาจได้รับผลกระทบ



Threat Actor Profiles

โปรไฟล์ภัยคุกคามของกลุ่ม Suspected Chinese Operators (Op-Chinese-Operators)

1. ประวัติและภูมิหลัง

จากการวิเคราะห์ข้อมูลที่ได้จากเซิร์ฟเวอร์ C2 ทางทีมวิเคราะห์ได้ประเมินระดับความเชื่อมโยงไปยังกลุ่มผู้ไม่หวังดีสัญชาติจีน ด้วยความเชื่อมั่นระดับปานกลาง โดยอาศัยหลักฐานแวดล้อมดังนี้:

- **โปรไฟล์ของเป้าหมาย:** มีการมุ่งเป้าอย่างเจาะจงไปยังองค์กรในประเทศได้วันถึง 10 แห่ง ซึ่งครอบคลุมอุตสาหกรรมการเดินเรือ เซมิคอนดักเตอร์ การผลิตหุ่นยนต์ และอากาศยานไร้คนขับ (UAV) ซึ่งสอดคล้องกับผลประโยชน์และแรงจูงใจในการจารกรรมทางเศรษฐกิจของสาธารณรัฐประชาชนจีน
- **การใช้เทคโนโลยี AI:** มีการเรียกใช้งาน API ของ DeepSeek-v4-pro ซึ่งเป็นโมเดลภาษาขนาดใหญ่ที่พัฒนาในประเทศจีนมาใช้เป็นหน่วยประมวลผลการตัดสินใจหลัก (Reasoning Engine) ซึ่งหากเป็นกลุ่มผู้ปฏิบัติการฝั่งตะวันตกมักนิยมใช้งาน OpenAI หรือ Anthropic APIs มากกว่า
- **ที่ตั้งโครงสร้างเครือข่าย C2:** IP ของกลุ่มผู้ไม่หวังดี (112.213.124.0/24) ขึ้นไปยังผู้ให้บริการเครือข่ายของจีน
- **ขอบเขตเป้าหมายที่กว้างขวาง (Target Breadth):** การโจมตีครอบคลุมหลายภูมิภาค (ไต้หวัน ไทย ไนจีเรีย อัฟกานิสถาน อิตาลี บราซิล ออสเตรเลีย) ซึ่งสอดคล้องกับพฤติกรรมของกลุ่มภัยคุกคามที่มีรัฐหนุนหลังของจีนที่มักจะทำภารกิจเก็บรวบรวมข้อมูลในวงกว้าง ควบคู่ไปกับการปฏิบัติการเจาะจงเป้าหมายระดับสูง
- **ความสอดคล้องกับประวัติพฤติกรรม (MITRE ATT&CK Alignment):** พฤติกรรมการทำงาน (TTPs) มีส่วนทับซ้อนกับกลุ่ม APT41 (การจารกรรมควบคู่ไปกับแรงจูงใจทางการเงิน), APT10 (การมุ่งเป้าผู้ให้บริการไอที) และ Volt Typhoon (การฝังตัวล่วงหน้าในโครงสร้างพื้นฐานสำคัญ)

สมมติฐานทางเลือก:

- การใช้ชื่อเฟรมเวิร์กภายในว่า "claude-1000" (เพื่อเลียนแบบ Claude ของ Anthropic) อาจเป็นการจูงใจสร้างร่องรอยลงเพื่อเบี่ยงเบนความสนใจของนักวิเคราะห์
- ขอบเขตเป้าหมายที่มีทั้งภาครัฐและภาคการเงินในหลายประเทศ อาจมีความเป็นไปได้ที่จะเป็นฝีมือของกลุ่มรับจ้างแฮกข้อมูล ที่แสวงหาประโยชน์ทางการเงิน มากกว่าจะเป็นกลุ่มปฏิบัติการจารกรรมข้อมูลเพื่อรัฐโดยตรง

2. เครื่องมือการโจมตี (Toolset)

ประเภท	เครื่องมือ	รายละเอียด
AI Hacking Framework	Claude Code v2.1.165	Agentic execution engine, managing terminal sessions, maintaining persistence
AI Reasoning Model	DeepSeek-v4-pro	Attack reasoning logic, exploit adaptation, evasion decision-making
C2 Malware & Core Infra	TencShell (ARM/x86) Gshell C2 Framework	Go-based implant derived from Rshell (WebSocket over port 4081) Secondary redundant C2 framework (TLS CN="Gshell Server")
Reconnaissance & Scanning	httpx, katana, Nuclei ARL (port 5003) deep_probe.py, manual_recon.py	Fast HTTP probing, JS crawling, vulnerability scanning, active fingerprinting
Exploitation Frameworks	sqlmap, jexboss, phpggc RAU_crypto, cve-2017-12149.py	Automated SQLi, JBoss serialization exploits, Telerik AsyncUpload exploit



ประเภท	เครื่องมือ	รายละเอียด
Web Shells & Backdoors	amss_alfa_py.alfa, shell.war shell.gif.php, evil.gif.php c3_shell.php.gif, Vshell	Python CGI shell, Java WAR shell, double extension and GIF polyglot shells
Custom Exploit Scripts	laravel_rce.py smuggle_final_exploit.py smuggle_fpm.py pma_bf_final.py, ssh_root_bf.py	Monolog deserialization, HTTP/2 smuggling, PHP-FPM hijacking, brute-force

3. กลุ่มเป้าหมาย

- **ภาครัฐ:** หน่วยงานบริหารของรัฐบาล (ไทย, อัฟกานิสถาน, ไนจีเรีย) และระบบรับเรื่องร้องเรียนของประชาชน
- **ภาคอุตสาหกรรมและการป้องกันประเทศ:** บริษัทในห่วงโซ่อุปทานของไต้หวัน (การเดินเรือ, เซมิคอนดักเตอร์, โดรน, หุ่นยนต์)
- **ภาคโทรคมนาคม:** ผู้ผลิตอุปกรณ์ Edge Device รายใหญ่
- **ภาคการเงิน:** บริษัทประมวลผลการชำระเงิน ธนาคาร และแพลตฟอร์มการเงินข้ามประเทศ (ยุโรป, ออสเตรเลีย, เอเชีย)
- **สหรัฐอเมริกา:** การสอดแนมขั้นต้นต่อ NASA Hosts และการเตรียมหน้า Phishing ปลอมเพื่อโจมตี D.C. Council และ Delaware County



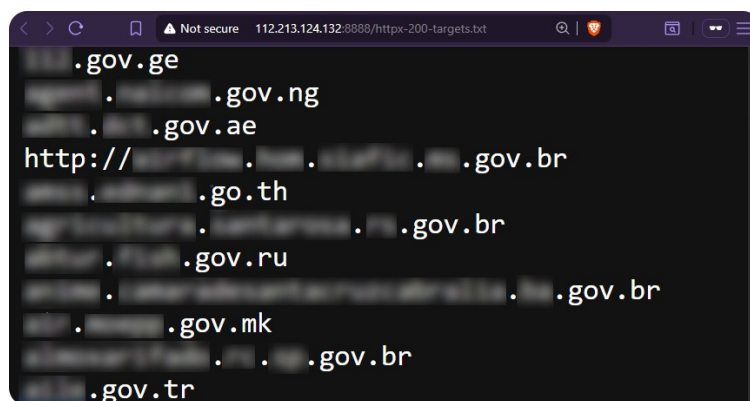
การวิเคราะห์เชิงเทคนิค

จากการวิเคราะห์เชิงลึกสามารถสรุปลำดับขั้นตอนการโจมตี (Attack Flow) และเจาะลึกโครงสร้างทางเทคนิคได้ดังนี้:

ลำดับขั้นตอนการโจมตี (Attack Flow)

1. การสอดแนมและสำรวจโครงสร้างพื้นฐาน (Reconnaissance)

ผู้ไม่หวังดีใช้เครื่องมือ httpx และ katana ในการ Crawl Subdomain และตรวจสอบ Open Services อย่างเป็นระบบ โดยผลลัพธ์ถูกจัดเก็บในไฟล์เป้าหมายสองชุด ได้แก่ alive_targets.txt (ขนาด 15,780 bytes) และ all_targets.txt (ขนาด 31,041 bytes) ซึ่งแสดงให้เห็นถึงขนาดของการปฏิบัติการที่กว้างขวาง นอกจากนี้ยังพบสคริปต์ Bash ที่กำหนดเป้าหมายเฉพาะเจาะจงต่อบริษัทในได้หวัน 8 แห่งพร้อมกัน โดยทำการ DNS Brute-forcing, Certificate Transparency Queries, Adjacent IP Discovery และ HTTP Service Fingerprinting ร่วมกับการสแกน ARL (บนพอร์ต 5003) และ DeepAudit (บนพอร์ต 3000) เพื่อสร้างแผนที่ช่องโหว่ของเป้าหมาย



รูปที่ 1 ตัวอย่างเป้าหมายในการใช้เครื่องมือ httpx

2. การค้นหาช่องโหว่ด้วย AI (Automated Vulnerability Discovery)

หลังจากได้รายการเป้าหมาย ผู้ไม่หวังดีใช้ Framework claude-1000 ในการ Deploy Nuclei Templates ผ่าน run_nuclei.py และ Custom Probes ผ่าน deep_probe.py เพื่อสแกนช่องโหว่อย่างอัตโนมัติ AI Agent ทำหน้าที่วิเคราะห์ Technology Stack ที่ตรวจพบ (ได้แก่ Laravel, WordPress, Telerik, Joomla, JBoss, ASP.NET) และเลือก Exploit ที่เหมาะสมสำหรับแต่ละเป้าหมายโดยไม่ต้องมีการตัดสินใจจากมนุษย์ ทำให้กระบวนการ Vulnerability Assessment ที่ปกติต้องใช้เวลาหลายวันถูกย่อเหลือเพียงไม่กี่ชั่วโมง



3. การโจมตีและเจาะระบบ (Exploitation)

ผู้ไม่หวังดีใช้ช่องโหว่หลายรูปแบบตามความเหมาะสมของแต่ละเป้าหมาย:

เทคนิค	เป้าหมาย	รายละเอียด
Blind SQL Injection	ไทย (AMSS) ไต้หวัน (Transchief)	AI สร้าง Multi-threaded Python Scripts สำหรับ Time-based / Boolean-based SQLi ต่อ Parameter kind0 และ Login Forms
Exposed .git Directory	อัฟกานิสถาน (AOP) ไต้หวัน (Coretronic)	ใช้ git_extract.py Clone Full Laravel Repository รวมถึง .env.swp ที่มี Plaintext Credentials
Laravel Monolog Deserialization	อัฟกานิสถาน (aop.gov.af)	PHP Object Deserialization ผ่าน laravel_rce.py / laravel_exploit_full.py ต่อ Laravel v5.8.38
Telerik AsyncUpload RCE	อิตาลี (lavoropubblico.gov.it)	CVE-2017-11317 / CVE-2019-18935 ผ่านเครื่องมือ RAU_crypto
WordPress REST API Abuse	ไนจีเรีย (nemsa.gov.ng)	สร้าง Application Password ผ่าน Backend API และ Inject Custom REST Route /wp-abilities/v1/abilities/{cmd}
Hardcoded Cloud Credentials	ไต้หวัน (Zyxel, Yang Ming)	ค้นพบ Supabase Anon Keys, Azure Logic App SAS URLs และ Azure AD Tenant ID ที่ Hardcode อยู่ใน JavaScript Files
HTTP PUT Web Shell Upload	บราซิล, อาร์เจนตินา, ออสเตรเลีย, UAE, ปาเลสไตน์	อัปโหลด Web Shell โดยตรงผ่าน HTTP PUT Method บนเซิร์ฟเวอร์ที่ไม่ได้ปิด PUT Endpoint



4. การเก็บเกี่ยวข้อมูลยืนยันตัวตน (Credential Harvesting)

หลังจากเจาะระบบสำเร็จ AI Agent ทำการดึงข้อมูล Credentials ทุกประเภทที่พบในระบบ ได้แก่ Database Credentials, Application Passwords, Laravel APP_KEY, Active Session Cookies, Supabase Anon Keys, Azure SAS URLs และ AWS SES SMTP Credentials โดย Credentials เหล่านี้ถูกจัดเก็บใน C2 เพื่อใช้สำหรับการ Re-access ในอนาคตและการโจมตีระบบอื่นที่เชื่อมต่อกัน นอกจากนี้ยังมีการพยายาม Azure AD Device Code Flow Interception เพื่อขโมย OAuth2 Tokens ของบริษัทเดินเรือ Yang Ming Marine

5. การฝังตัวและรักษาการเข้าถึง (Persistence & Backdoor Deployment)

ผู้ไม่หวังดีเตรียม Web Shell ไว้มากกว่า 80 Variant บนเซิร์ฟเวอร์ C2 เพื่อรองรับทุกสถานการณ์การอัปเดต โดยมีรูปแบบที่หลากหลาย ดังนี้:

- **amss_alfa_py.alfa:** Python CGI Alfa Shell รับคำสั่งผ่าน POST + Base64 Decoding
- **shell.war:** Java Application Server Backdoor สำหรับ JBoss/Tomcat
- **shell.gif.php / evil.gif.php:** Double Extension Bypass เลียนแบบ Image File
- **test_shell.phtml / .pht / .php5:** Extension Bypass Probes
- **c3_shell.php.gif:** GIF Header Prepend PHP Shell (Polyglot Technique)

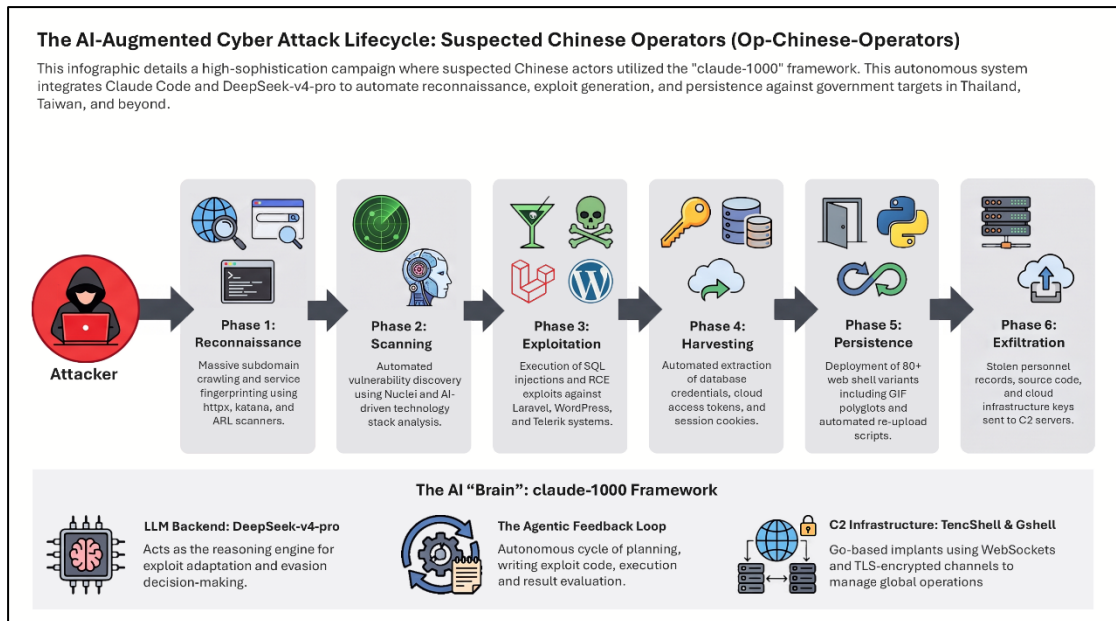
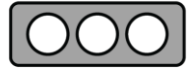
สำหรับระบบ AMSS ของหน่วยงานไทย ยังมีการ Deploy amss_auto_getshell.sh ซึ่งทำการ Re-upload Backdoor โดยอัตโนมัติทุก 5 นาทีหากเซิร์ฟเวอร์ Restart และมีการ Inject /wp-abilities/v1/abilities/{cmd} Route บน WordPress ของระบบไนจีเรีย NEMSA เพื่อ RCE ผ่าน `base64_decode($cmd) → shell_exec()`



6. การส่งออกข้อมูลและผลกระทบ (Data Exfiltration & Impact)

ข้อมูลที่ถูกขโมยออกไปยังเซิร์ฟเวอร์ C2 ที่ 112.213.124[.]132:8888 มีดังนี้:

เป้าหมาย	ข้อมูลที่ถูกขโมย	ขนาด/จำนวน
ไทย: AMSS	ข้อมูลเจ้าหน้าที่รัฐบาล (ชื่อ, ตำแหน่ง, หมายเลขบัตรประชาชน)	ไม่ทราบจำนวน (900+ Response Captures)
อัฟกานิสถาน: AOP	Full Laravel Source Code, Database Config, Encryption Keys, Session Tokens	ทั้ง Repository
ไต้หวัน: Coretronic Robotics	Source Code ทั้งโปรเจกต์ + Database Credentials + AWS SES Keys	216 PHP Files + 76 JS Files
ไต้หวัน: Transchief	ฐานข้อมูลสินค้าผ่าน Automated SQLi	123 Product Records
ไต้หวัน: Zyxel	Backend SSO Keys, 5 Azure Logic App SAS URLs, Google Cloud Storage Keys	Cloud Infrastructure Access
ไต้หวัน: Yang Ming Marine	Azure AD Tenant ID, 3 OAuth Client IDs, App Insights Keys	Cloud Identity Mapping
ไนจีเรีย: NEMSA	WordPress Admin Access พร้อม RCE Capability ต่อเนื่อง	Backdoor Active



รูปที่ 2 แผนภาพ Attack Flow ของ Op-Chinese-Operators

การโจมตีอัตโนมัติด้วย AI: "claude-1000" Framework

จากการวิเคราะห์เชิงลึกพบว่า ไดรอกทอรีเปิดบนเซิร์ฟเวอร์ C2 เก็บหลักฐานที่สำคัญที่สุดของแคมเปญนี้ นั่นคือการโจมตีอัตโนมัติที่ผู้ไม่หวังดีตั้งชื่อภายในว่า "claude-1000" ซึ่งเป็นการนำ AI มาใช้เป็นสมองกลในการโจมตีอย่างอัตโนมัติตั้งแต่ต้นจนจบโดยไม่ต้องมีการแทรกแซงของมนุษย์ นับเป็นหนึ่งในหลักฐานว่ากลุ่มภัยคุกคามได้ Deploy Autonomous AI Hacking Agent ในปฏิบัติการจริง

รายการ	รายละเอียด
Framework Path	/claude-1000/ บนเซิร์ฟเวอร์ C2 112.213.124[.]132:8888
LLM Backend	deepseek-v4-pro (API ของจีน)
Session Storage	/claude-1000/-wzzz-hack-skills/ จัดเก็บ Sessions แยกตาม UUID
Task Logs	874 .output files บันทึกการทำงานของ AI Agent ทุกขั้นตอน
Instruction File	CLAUDE.md — ไฟล์ที่มีคำสั่งให้ AI สร้าง ทดสอบ และวนซ้ำ Phishing Pages
Claude Code Version	v2.1.165

กลไกการทำงาน (Agentic Loop)

ผู้ไม่หวังดีออกคำสั่งระดับสูงให้ Framework (เช่น "ค้นหาช่องโหว่ SQL Injection และดึงข้อมูลจาก User Tables") จากนั้น claude-1000 ดำเนินการโดยอัตโนมัติใน Feedback Loop ดังนี้:

1. **Plan:** DeepSeek-v4-pro วิเคราะห์เป้าหมายและวางแผนการโจมตี
2. **Write:** AI เขียน Python Exploit Script เฉพาะสำหรับเป้าหมายนั้น
3. **Execute:** Claude Code รันสคริปต์ผ่าน Bash และรวบรวม HTTP Response
4. **Evaluate:** AI อ่านผลลัพธ์ ปรับแก้ Script หากล้มเหลว วนซ้ำโดยไม่ต้องการการดูแลจากมนุษย์

พฤติกรรมที่บันทึกได้จาก Task Logs (874 Sessions)

พฤติกรรม	รายละเอียด
Blind SQL Injection	AI สร้าง Multi-threaded Python Scripts สำหรับ Time-based และ Boolean-based SQLi บนพารามิเตอร์เป้าหมาย
Automated Script Generation	AI เขียนและปรับปรุง Exploit Scripts แบบวนซ้ำตาม HTTP Response Feedback
API Data Harvesting	AI Parse WordPress REST API, Drupal JSON:API และ JavaScript Bundles เพื่อดึง Credentials
Web Shell Deployment	อัปโหลด PHP/Python/Perl Web Shells ผ่าน PUT Method, File Upload Endpoints และ Telerik AsyncUpload
OAuth/SSO Hijacking	ทดลองดัก Azure AD Device Code Flow และขโมย OAuth2 Tokens
Git Repository Cloning	ใช้ประโยชน์จาก Exposed .git Directories เพื่อ Clone Source Code และดึง .env Secrets
Automated Persistence	Deploy Script ที่ตรวจสอบสถานะ Target และ Re-upload Backdoor อัตโนมัติเมื่อ Server Restart
Phishing Page Iteration	AI สร้าง ทดสอบ และวนซ้ำปรับปรุง Cloned Login Pages สำหรับหลายเป้าหมาย

[illegible]

รูปที่ 3 ภาพ Snippet ของ Output Log Files หนึ่งในหลายร้อยไฟล์ที่พบในไดเรกทอรี claude-1000

แสดงการทำงานของ AI Agent ในการเขียนและรัน Exploit Scripts ต่อเป้าหมาย

คุณลักษณะทางเทคนิคของมัลแวร์และโครงสร้างพื้นฐาน

1. TencShell: Go-based C2 Implant

TenShell เป็น Go-based implant ที่ถูกคอมไพล์แบบ Statically Linked และส่งผ่านทาง HTTP GET Request บนพอร์ต 1111 ของเซิร์ฟเวอร์ C2 โดยตัวอย่างที่ค้นพบมีทั้งสถาปัตยกรรม Linux/ARM 32-bit (HSEWH-Ur, 8eA-GlbK, r4l3DqLA) และ Linux/x86 (Ar70qlCi) โดยทั้งสองรุ่นใช้การสื่อสาร WebSocket บนพอร์ต 4081 พร้อม HTTP Authentication Headers ได้แก่ X-NITRO-USER และ X-NITRO-PASS ซึ่งเลียนแบบ Header ของ Legitimate Infrastructure Management API ความสามารถของมัลแวร์ที่ค้นพบรวมถึงการดึงข้อมูล Credentials จาก Tencent QQ/IM Platform, Cloud Service Access Keys และการ Upload/Download ไฟล์ผ่าน C2

ที่น่าสังเกตคือ ตัวอย่าง x86 บน 38.55.105[.]143:8088 มีการใช้เครื่องมือ Garble เพื่อลบ Function และ Variable Names ออก (Anti-Forensics) แต่ทั้งสองตัวอย่างแชร์ Encryption Key ขนาด 80 Bytes ที่เหมือนกัน ยืนยันว่ามาจาก Codebase เดียวกัน

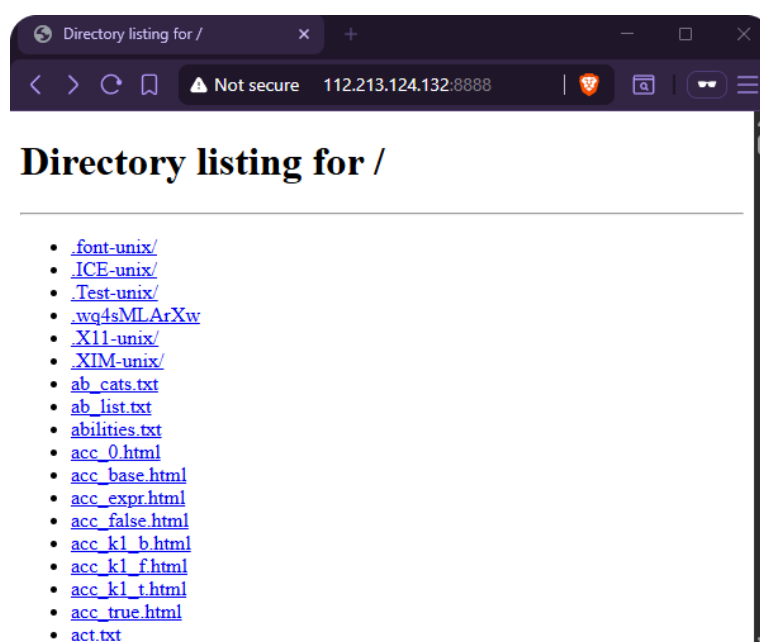


2. GIF Polyglot Webshell: เทคนิคหลบเลี่ยงการตรวจจับ

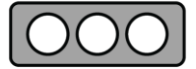
สำหรับการโจมตีระบบภาครัฐของไทย ผู้ไม่หวังดีใช้ GIF Polyglot Webshell ซึ่งเป็นไฟล์ที่มีโครงสร้างของ GIF Image Header แต่มีโค้ด PHP สำหรับรับคำสั่งซ่อนอยู่ภายใน เทคนิคนี้ถูกออกแบบมาเพื่อหลบเลี่ยงการตรวจจับของระบบ IDS/IPS ที่กรองเฉพาะ File Extension โดยไม่วิเคราะห์เนื้อหาของไฟล์ (Content-Type Bypass)

3. Gshell — C2 Framework ร่อง

Gshell ถูกระบุตัวตนผ่าน TLS Certificate ที่มีค่า Subject: CN = Gshell Server และ O = Gshell C2 บนพอร์ต 443 และ 8083 โดยพบเซิร์ฟเวอร์จำนวน 9 เครื่องที่ใช้ Certificate นี้ ซึ่งทั้งหมดตั้งอยู่ในฮ่องกงภายใต้ Antbox Networks Limited และ CTG Server Limited การที่ทั้ง TencShell และ Gshell ปรากฏบน IP เดียวกัน (192.229.115[.]229 และ .230) ชี้ให้เห็นว่า Framework ทั้งสองถูกใช้งานพร้อมกันโดยผู้ปฏิบัติการกลุ่มเดียวกัน เพื่อเพิ่มความทนทานและซับซ้อนในการปฏิบัติการ



รูปที่ 4 ภาพหน้าจอ Open Directory บน 112.213.124[.]132:8888



Timeline การโจมตี

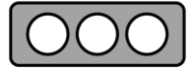
วัน / เวลา (UTC)	เหตุการณ์	รายละเอียด
17 พ.ค. 2569	SSH Host Key Sharing เริ่มต้น	112.213.124[.]132, .159 และ .163 เริ่มใช้ SSH Key Fingerprint 64107E3E... ร่วมกัน บ่งชี้การ Deploy โครงสร้างพื้นฐาน
8 มิ.ย. 2569	Claude Code Sessions เริ่มต้น	Session IDs ระบุการเริ่มต้นปฏิบัติการโจมตีด้วย Claude Code v2.1.165 โดยมี Session แยกสำหรับแต่ละเป้าหมายทางภูมิศาสตร์
8–12 มิ.ย. 2569	Taiwan Campaign	ปฏิบัติการต่อเป้าหมายในไต้หวัน 8+ บริษัท บันทึก Session ใน Dedicated Working Directories
9 มิ.ย. 2569	AMSS Thailand Confirmed Breached	หลักฐานยืนยันการเข้าถึง Admin Panel ของระบบ AMSS พร้อม GIF Polyglot Webshell ถูก Deploy
10 มิ.ย. 2569	HuntSQL Discovery	ค้นพบ 13 IP Addresses ที่แชร์ HTTP Header Hash เดียวกัน โดยใช้ SHA256: 03f26cbf...
11 มิ.ย. 2569	Taiwan Supply Chain Latest Activity	Timestamps ล่าสุดในไต้หวันแสดงถึงการดำเนินงานต่อเนื่องต่อเป้าหมาย Supply Chain ในไต้หวัน
18–19 มิ.ย. 2569	ARL Certificate Reissue	ทั้งสามเซิร์ฟเวอร์หลักออก ARL TLS Certificate ใหม่ (SHA-256: 2954639B...) บ่งชี้การ Redeployment/Restart ของ ARL



Tactics, Techniques, and Procedures (MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Reconnaissance	T1595.002	Active Scanning: Vulnerability Scanning
	T1589	Gather Victim Identity Information
Resource Development	T1588.007	Obtain Capabilities: Artificial Intelligence
Initial Access	T1190	Exploit Public-Facing Application
	T1566	Phishing
Execution	T1059.006	Command & Scripting Interpreter: Python
Persistence	T1505.003	Server Software Component: Web Shell
	T1078.004	Valid Accounts: Cloud Accounts
Defense Evasion	T1036.008	Masquerading: Masquerade File Type
	T1036.007	Masquerading: Double File Extension
Credential Access	T1552.001	Unsecured Credentials: Credentials in Files
	T1110.001	Brute Force: Password Guessing
Discovery	T1083	File and Directory Discovery
Collection	T1213.003	Data from Information Repositories: Code Repositories
	T1213.006	Data from Information Repositories: Databases



Tactic	Technique ID	Technique Name
Command & Control	T1105	Ingress Tool Transfer
	T1071.001	Application Layer Protocol: Web Protocols
Exfiltration	T1041	Exfiltration Over C2 Channel
Impact	T1565.001	Data Manipulation: Stored Data Manipulation

Indicators of Compromise (IoCs)

Indicators of Compromise (IoCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IoCs ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

ร่องรอยที่สามารถตรวจสอบได้:

File Hashes (SHA-256)

Hash	Malware Family
90b7b2c6f3d05234dc55678243039d7e51f0d54190239e5234a000553337dc8	TencShell ARM (HSEWH-Ur, 8eA-GlbK, r4L3DqLA)
643de2a1cf9148b896efecf560c9476fa56118ec477c4e15eb5c2da4b318061f	TencShell x86 (Ar70qCi)

Network Infrastructure — TencShell C2

IP Address (Defanged)	Port	Context
112[.]213[.]124[.]132	1111, 8888	Primary C2 / Malware Delivery / Open Directory
112[.]213[.]124[.]159	1111, 8888	Malware Delivery / Open Directory
112[.]213[.]124[.]163	1111	Malware Delivery / Open Directory
192[.]229[.]115[.]229	8090	TencShell & Gshell Dual Infrastructure
192[.]229[.]115[.]230	8090	TencShell & Gshell Dual Infrastructure
45[.]64[.]52[.]242	1111	Cato Networks IoC (CTG Server Limited, HK)
45[.]64[.]52[.]245	1111	Suspected TencShell Infrastructure
45[.]64[.]52[.]246	1111	Suspected TencShell Infrastructure
134[.]122[.]200[.]153	443	Suspected TencShell Infrastructure
134[.]122[.]200[.]154	443	Suspected TencShell Infrastructure
134[.]122[.]200[.]155	443	Suspected TencShell Infrastructure
192[.]238[.]134[.]166	1212	Suspected TencShell Infrastructure
38[.]55[.]105[.]143	8088	Malware Delivery(XNNET LIMITED / VMIS Inc., HK)



Network Infrastructure — Gshell C2

IP Address (Defanged)	Context
192[.]163[.]167[.]5	Gshell Certificate Match (Antbox Networks Limited, HK)
192[.]163[.]167[.]6	Gshell Certificate Match (Antbox Networks Limited, HK)
192[.]163[.]167[.]7	Gshell Certificate Match (Antbox Networks Limited, HK)
192[.]163[.]167[.]10	Gshell Certificate Match (Antbox Networks Limited, HK)
134[.]122[.]200[.]114	Gshell Certificate Match (CTG Server Limited, HK)
134[.]122[.]200[.]115	Gshell Certificate Match (CTG Server Limited, HK)
134[.]122[.]200[.]116	Gshell Certificate Match (CTG Server Limited, HK)

TLS Certificate Fingerprints

SHA-256	Context
AD1A0B3E22A10A2BD680B773B178A0D3824CFCBDF3551016F3D052A0B823079F	ARL Default Cert (Original, C=CN, ST=Shanghai, CN=127.0.0.1)
2954639BE599F23C2229A9743ABA09A1D9D11BF2BECC62BF353384437DB37DEE	ARL Cert Reissued 18–19 Jun 2026 (post-redeployment)

SSH Host Key Fingerprint

Fingerprint	Context
64107E3E0A333F685D1BE6386426223A030C4126AC7C295AA7B1D54C508BBACE	Shared SSH Key (.132, .159, .163) — Active since 17 May 2026



แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

- **การตรวจจับ Network Traffic:** ให้ตรวจสอบ Traffic ที่มุ่งสู่ หรือที่มาจาก IP Addresses ทั้ง 20 รายการในตาราง IOCs อย่างเร่งด่วน โดยเฉพาะอย่างยิ่งการเชื่อมต่อบนพอร์ต 1111, 4081, 8083, 8084, 8088 และ 8090 ซึ่งเป็น Non-Standard Ports ที่ใช้โดย TencShell และ Gshell นอกจากนี้ควรตรวจสอบ HTTP Header ที่มีรูปแบบ X-NITRO-USER และ X-NITRO-PASS ซึ่งเป็น Signature เฉพาะของ TencShell
- **การตรวจจับ TLS Certificate:** ให้ตั้งค่าระบบเฝ้าระวัง TLS/SSL ขององค์กรให้แจ้งเตือนเมื่อพบ Certificate ที่มีค่า CN = Gshell Server หรือ O = Gshell C2 หรือ SHA-256 Fingerprints ที่ระบุไว้ในส่วน IOCs
- **การตรวจจับ AI-Augmented Attacks:** เนื่องจากแคมเปญนี้ใช้ AI ในการสร้าง Exploit Scripts ที่หลากหลายและปรับเปลี่ยนอยู่ตลอดเวลา การพึ่งพาเพียง Signature-Based Detection จึงไม่เพียงพอ ผู้ดูแลระบบควรเพิ่ม Behavioral Anomaly Detection สำหรับการตรวจสอบรูปแบบการเข้าถึง Admin Panel ที่ผิดปกติ การส่ง SQL Queries ที่มีความซับซ้อนสูงในระยะเวลาสั้น และการอัปโหลดไฟล์ผ่านช่องทางที่ไม่ปกติ



การป้องกัน (Prevention)

- บล็อก IP Range 112.213.124.128/25 และ IP Addresses ทั้งหมดในตาราง IOCs ที่ Perimeter Firewall และ WAF ทันที
- ปิดการเข้าถึงสาธารณะต่อไดเรกทอรี .git ของระบบ Web Application ทุกระบบที่เปิดให้บริการสู่อินเทอร์เน็ต
- ตรวจสอบไฟล์ JavaScript สาธารณะทุกไฟล์ว่าไม่มีการฝัง API Keys, Cloud Access Tokens หรือ Database Credentials ไว้ภายใน
- สแกนหาไฟล์ .alfa, .phtml, .pht, .php5 หรือ .htaccess ที่ถูกแก้ไขโดยไม่ได้รับอนุญาต บน Web Server Document Root
- อัปเดต Framework ที่ล้าสมัย โดยเฉพาะ Laravel เวอร์ชันต่ำกว่า 8.x ซึ่งมีช่องโหว่ Deserialization ที่ถูกนำมาใช้โจมตี
- บังคับใช้ Parameterized Queries และ Prepared Statements ในทุก Web Application ที่มีการรับข้อมูลจากผู้ใช้งาน
- เปิดใช้งาน File Integrity Monitoring (FIM) บน Web Server Document Root ทุกเครื่อง



การรับมือ (Response)

- ทำการ Isolate ระบบที่ต้องสงสัยออกจากเครือข่ายทันทีเพื่อป้องกันการแพร่กระจาย
- เปลี่ยน Credentials ทั้งหมดบนระบบที่อาจได้รับผลกระทบ รวมถึง Database Passwords, Application Keys และ Cloud Access Tokens
- ทำการ Forensic Analysis อย่างละเอียดบนระบบที่ได้รับผลกระทบ โดยเน้นการตรวจสอบ Web Shell, Backdoor และ Persistent Mechanisms
- ดำเนินการ Threat Hunting เชิงรุกโดยใช้ IOCs ในรายงานนี้เพื่อค้นหาร่องรอยการบุกรุกบนระบบอื่นๆ ในองค์กร
- แจ้ง ThaiCERT ทันที เมื่อพบหลักฐานการโจมตีเพื่อการประสานงาน Incident Response

อ้างอิง (References)

1. Hunt.io. (2026, July 14). **Suspected Chinese Operators Use Claude Code and DeepSeek to Breach Government Systems Across Four Countries.** Retrieved from <https://hunt.io/blog/chinese-operators-claude-deepseek-government-intrusion>
2. Cato CTRL. (2026, May). **Cato CTRL Threat Research: Suspected China-Linked Threat Actor Targets Global Manufacturer with Undocumented TencShell Malware.** Cato Networks. Retrieved from <https://www.catonetworks.com/blog/cato-ctrl-suspected-china-linked-threat-actor-targets-global-manufacturer/>
3. Anthropic. (2025, November). **Disrupting the first reported AI-orchestrated cyber espionage campaign.** Anthropic. Retrieved from <https://www.anthropic.com/news/disrupting-AI-espionage>
4. MITRE Corporation. (2024). **MITRE ATT&CK Enterprise Matrix.** Retrieved from <https://attack.mitre.org/>
5. Security Affairs. (2026, July 16). **Claude Code and DeepSeek Powered Chinese Cyber Espionage Campaign.** Retrieved from <https://securityaffairs.com/195474/ai/claude-code-and-deepseek-powered-chinese-cyber-espionage-campaign.html>
6. Cyber Security News. (2026, July 15). **Chinese Hackers Embed Claude Code and DeepSeek in AI-Powered Government Cyberattacks.** Retrieved from <https://cybersecuritynews.com/chinese-hackers-ai-attacks>
7. CCb0unce. (2024). **Asset Reconnaissance Lighthouse (ARL).** GitHub. Retrieved from <https://github.com/CCb0unce/ARL>
8. lintsinghua. (2024). **DeepAudit.** GitHub. Retrieved from <https://github.com/lintsinghua/DeepAudit>



แบบประเมินรายงานข่าวกรองไซเบอร์

<https://forms.gle/2cTSw2fDoMzFDGEW9>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th